Matriz de seguridad · roles, objetos y permisos

> **Proyecto 2 · Entregable 2 — DBSuperHamburguesas** · TIIT3175.2 Bases de Datos III Universidad Invenio · 22 de septiembre de 2026

Doce roles de dominio, uno de consulta y uno de gestión por cada uno de los seis esquemas de negocio. **Los 101 permisos están concedidos al rol; ninguno a un usuario.** Lo que no aparece en esta matriz no está concedido: el modelo es cerrado por omisión y no usa denegaciones puntuales.

1. Usuarios y membresías

Usuario	Rol	Dominio
`usr_ana_rodriguez`	`rol_catalogo_consulta`	Catálogo
`usr_andres_rodriguez`	`rol_catalogo_gestion`	Catálogo
`usr_carlos_castro`	`rol_ventas_consulta`	Ventas
`usr_daniela_delgado`	`rol_ventas_gestion`	Ventas
`usr_esteban_vargas`	`rol_inventario_consulta`	Inventario
`usr_fernanda_mora`	`rol_inventario_gestion`	Inventario
`usr_gabriela_gonzalez`	`rol_rrhh_consulta` **y** `rol_catalogo_consulta`	RR. HH. y Catálogo
`usr_jose_jimenez`	`rol_rrhh_gestion`	RR. HH.
`usr_laura_solano`	`rol_proveedores_consulta`	Proveedores
`usr_luis_solano`	`rol_proveedores_gestion`	Proveedores
`usr_maria_mendez`	`rol_contabilidad_consulta`	Contabilidad
`usr_mauricio_mendez`	`rol_contabilidad_gestion`	Contabilidad

`usr_gabriela_gonzalez` tiene doble membresía a propósito: permite demostrar que los permisos se acumulan por rol y que cada conjunto se puede retirar por separado.

2. Catálogo

Objeto	rol_catalogo_consulta	rol_catalogo_gestion
catalogo.Hamburguesa	SELECT	SELECT, INSERT, UPDATE
catalogo.Ingrediente	SELECT **solo** (IngredienteID, Nombre, UnidadMedida, Activo)	SELECT, INSERT, UPDATE
catalogo.RecetaHamburguesa	SELECT	SELECT, INSERT, UPDATE, DELETE
catalogo.TipoImpuesto	SELECT	SELECT, INSERT, UPDATE
catalogo.HamburguesaImpuesto	SELECT	SELECT, INSERT, UPDATE, DELETE

Caso 1 de información sensible. `CostoReferencia` queda fuera de la concesión al rol de consulta: el costo de compra de un ingrediente es información comercial, no operativa.

3. Ventas

Objeto	rol_ventas_consulta	rol_ventas_gestion
ventas.Cliente	SELECT	SELECT, INSERT, UPDATE
ventas.EstadoPedido	SELECT	SELECT
ventas.Pedido	SELECT	SELECT, INSERT, UPDATE
ventas.PedidoDetalle	SELECT	SELECT, INSERT, UPDATE
catalogo.Hamburguesa	SELECT	SELECT
catalogo.TipoImpuesto	SELECT	SELECT

Ventas no recibe DELETE sobre el pedido: un pedido se cancela cambiando su estado, no borrándolo, para que el historial comercial quede íntegro. Tampoco modifica el catálogo, solo lo consulta.

4. Inventario

Objeto	rol_inventario_consulta	rol_inventario_gestion
inventario.ExistenciaIngrediente	SELECT	SELECT, INSERT, UPDATE
inventario.TipoMovimientoInventario	SELECT	SELECT
inventario.MovimientoInventario	SELECT	SELECT, INSERT
catalogo.Ingrediente	SELECT **solo** (IngredienteID, Nombre, UnidadMedida, Activo)	SELECT (todas las columnas, sin modificar)

El historial de movimientos recibe INSERT pero **nunca** DELETE ni UPDATE: es un registro inmutable. Una corrección se hace con un movimiento de signo contrario, no borrando el original.

5. Recursos humanos

Objeto	`rol_rrhh_consulta`	`rol_rrhh_gestion`
`rrhh.Departamento`	SELECT	SELECT, INSERT, UPDATE
`rrhh.Puesto`	SELECT	SELECT, INSERT, UPDATE
`rrhh.Empleado`	SELECT **solo** (EmpleadoID, Nombre, Apellido, Telefono, Correo, FechaIngreso, DepartamentoID, PuestoID, Estado)	SELECT, INSERT, UPDATE (todas las columnas)

Caso 2 de información sensible. `Salario`, `Identificacion` y `FechaNacimiento` no están en la lista del rol de consulta. Un intento de leerlas devuelve el error 230. No hay vista intermedia ni prohibición explícita: la concesión enumera lo visible, y lo demás queda fuera por omisión.

6. Proveedores

Objeto	`rol_proveedores_consulta`	`rol_proveedores_gestion`
`proveedores.Proveedor`	SELECT	SELECT, INSERT, UPDATE
`proveedores.ProveedorIngrediente`	SELECT **solo** (ProveedorID, IngredienteID, TiempoEntregaDias)	SELECT, INSERT, UPDATE, DELETE
`catalogo.Ingrediente`	SELECT **solo** (IngredienteID, Nombre, UnidadMedida, Activo)	SELECT

Caso 3 de información sensible. `PrecioReferencia` queda fuera del rol de consulta: se puede saber quién suministra qué y en cuánto tiempo, pero no el precio negociado con cada proveedor.

7. Contabilidad

Objeto	`rol_contabilidad_consulta`	`rol_contabilidad_gestion`
`contabilidad.CuentaContable`	SELECT	SELECT, INSERT, UPDATE
`contabilidad.MovimientoContable`	SELECT	SELECT, INSERT, UPDATE

Ni siquiera el rol de gestión recibe DELETE sobre el asiento contable. Un asiento equivocado se corrige con un asiento de reverso, que queda registrado. El borrado lo ejecuta únicamente el DBA, y la auditoría lo registra.

8. Esquema administrativo

Objeto	Los doce roles de dominio
`SCHEMA::dba`	DENY SELECT, INSERT, UPDATE, DELETE, EXECUTE

Es la única denegación explícita del modelo, y se aplica a nivel de esquema: una sola sentencia cubre todos los objetos administrativos presentes y futuros, incluidos los de evidencia y los de configuración de respaldo.

9. Resumen cuantitativo

Medida	Valor
Roles	12
Usuarios	12
Membresías	13
Permisos concedidos	101
Permisos concedidos directamente a un usuario	0
Concesiones a nivel de columna	24
Denegaciones comprobadas rol × objeto	60
Denegaciones explícitas escritas	1 (esquema `dba`)
Pruebas de autorización ejecutadas / con el resultado esperado	15 / 15

10. Nota sobre los permisos CONNECT

`CREATE USER` concede automáticamente `CONNECT` sobre la base a cada entidad creada. Esos doce permisos figuran en el catálogo como concesiones directas a usuario y quedan excluidos de la comprobación del control DBA-SEG-01, que evalúa permisos de acceso a datos. El script los reporta en una consulta aparte para que la exclusión quede a la vista.